UNIVERSIDAD NACIONAL DE CONCEPCIÓN
FACULTAD DE CIENCIAS ECONÓMICAS Y ADMINISTRATIVAS
Ingeniería en Informática Empresarial

Manual de seguridad

FCEA Datasys

Controles del producto y operación del servidor

Trabajo Práctico Final de Ingeniería de Software I

Docentes
Prof. Lic. María Del Rosario Zorrilla A., Mg.
Prof. Ing. Juan Benito Torres Báez, Mg.

Integrantes
Alan Gabriel Cabrera Villalba
Ivan Ramon Duarte Villar
Fabrizio Ruben Larrosa Miranda
Thiago Mathias Torres Montania
Alan Amin Bogarín Godoy
Edgar Ibañez Meza

Concepción Paraguay
Octubre de 2026
Versión documental 1.0 al 27 de octubre de 2026

Índice de contenido

Propósito y alcance 1
Responsabilidades operativas 1
Activos y amenazas 2
Acceso y ciclo de vida de cuentas 2
Permisos por rol y por cuenta 3
Autenticación y sesiones 4
Contraseñas y recuperación 5
Confirmaciones y concurrencia 6
Seguridad de publicaciones y adjuntos 6
  Operación del almacenamiento privado 7
Auditoría inmutable 8
Copias manuales de la base de datos 8
  Estados y fallos del respaldo 9
Programación automática en el mismo servidor 10
  Verificación en Windows 10
  Verificación en Linux 11
Configuración y copia en Google Drive 11
  Acreditar acceso restringido y recuperar el archivo remoto 12
Restauración de PostgreSQL 13
  Ensayo real de restauración de esta entrega 14
Copias de adjuntos configuración y secretos 15
Instalación segura de producción 16
Gestión de secretos y configuración 17
Respuesta a incidentes 18
  Intento de acceso o cuenta comprometida 18
  Archivo malicioso o alterado 18
  Fallo de auditoría o de base de datos 18
  Fallo de copia o de nube 19
Verificaciones periódicas 19
Validación y límites conocidos 19
Fuentes y referencias 20

Índice de tablas

Tabla 1 Responsables y tareas 1
Tabla 2 Activos y controles principales 2
Tabla 3 Permisos iniciales 3
Tabla 4 Parámetros de autenticación 4
Tabla 5 Controles de archivo 6
Tabla 6 Resultado y respuesta operativa 9
Tabla 7 Resultado del ensayo de recuperación 14
Tabla 8 Registro operativo de continuidad 16
Tabla 9 Archivos que se mantienen privados 17
Tabla 10 Controles operativos recomendados 19

Propósito y alcance

Este manual establece cómo operar de forma segura FCEA Datasys al 27 de octubre de 2026. Explica los controles implementados de cuentas, permisos, sesiones, archivos y auditoría y los procedimientos de instalación, copias, recuperación e incidentes que corresponden a TIC. Distingue las funciones del software de las decisiones que debe tomar la institución sobre infraestructura, retención y continuidad.

La fuente principal es AGENTS.md y su ampliación de permisos del 26 de octubre. Se contrastó con el código del commit c277c82, los contratos de server/docs y las guías vigentes de instalación, permisos y Drive. El sistema conserva trabajos ya aprobados; no realiza evaluación académica ni verifica plagio. Los datos demo y sus credenciales públicas se utilizan únicamente para pruebas.

Responsabilidades operativas

Tabla 1 Responsables y tareas

Responsable funcional	Obligaciones
Investigación	Definir criterios de catalogación, validar la procedencia del trabajo y autorizar la política de acceso a la producción.
Biblioteca y Digitador	Comprobar metadatos, participantes, modalidad y obligación de conservación; comunicar rechazos y errores.
Administrador autorizado	Mantener cuentas, permisos y parámetros dentro de sus facultades; revisar reportes y auditoría.
TIC	Operar servidor, TLS, PostgreSQL, antivirus, SMTP, tareas, ACL, copias y recuperación; custodiar secretos.
Titular de cuenta	Proteger credenciales, cerrar sesión e informar actividad no reconocida.

Estos son responsables por función. La documentación no asigna cargos reales ni nombra personas como operadores de producción sin una designación institucional. Las acciones de la cuenta de servicio y los procedimientos de recuperación deben quedar en una bitácora operativa que complemente la auditoría del producto.

Activos y amenazas

Tabla 2 Activos y controles principales

Activo	Amenaza	Control
Metadatos y relaciones	Duplicación o pérdida de integridad	Normalización, UNIQUE, FK, bloqueos y transacciones.
Credenciales y sesiones	Acceso indebido o reutilización	Argon2id, sesión revocable, cookies y límites.
Adjuntos privados	Malware, exposición o alteración	Contenido, hash, ClamAV, almacenamiento privado y descarga auditada.
Política de permisos	Elevación o bloqueo administrativo	Revalidación, excepciones explícitas y protección del último gestor.
Auditoría	Manipulación o pérdida de trazabilidad	Trigger y grants sin UPDATE ni DELETE; fallo cerrado.
Backups	Pérdida local o acceso no autorizado	Copia local y Drive, acceso restringido, hash y ensayo de restauración.
Configuración y certificados	Filtración de secretos	Archivos privados fuera del cliente y Git; cuentas técnicas separadas.

Acceso y ciclo de vida de cuentas

Las cuentas se crean por un gestor autorizado; no existe registro público autónomo. CI, correo normalizado y nombre de usuario normalizado son únicos. La contraseña tiene entre 8 y 128 caracteres e incluye al menos una letra y un número. La base guarda Argon2id con sal, memoria 19456 KiB, dos iteraciones y paralelismo uno; esos parámetros proceden del código y deben calibrarse en el servidor destino sin debilitar la política unilateralmente.

1. Antes de crear una cuenta verificar la identidad y necesidad de acceso con el área responsable.
2. Asignar el rol inicial y únicamente las excepciones necesarias.
3. Entregar la contraseña inicial por un canal privado y solicitar cambio al titular.
4. Revisar periódicamente las cuentas activas y sus permisos; documentar la revisión.

5. Al retirar el acceso intentar inactivar conforme a las reglas de referencias y revocar sesiones. Si la aplicación lo impide por vínculos protegidos, TIC e Investigación deben revisar el caso sin borrar el histórico.

El nombre de una cuenta Público es de solo lectura cuando la cuenta anterior o nueva tiene ese rol. La cuenta propia no puede cambiar su rol o estado mediante mantenimiento de usuarios. La eliminación física se permite solo si no hay referencias; sesiones, auditoría propia, publicaciones o archivos pueden impedirla. No se utiliza DELETE directo en SQL para evadir el control.

Permisos por rol y por cuenta

Tabla 3 Permisos iniciales

Acción	Admin	Digitador	Público
Consultar catálogo y buscar	Sí	Sí	Sí
Perfil y contraseña propia	Sí	Sí	Sí
Registrar y editar publicaciones	Sí	Sí	No
Cargar y descargar adjuntos	Sí	Sí	No
Gestionar autores y tutores	Sí	Sí	No
Inactivar publicaciones y ver historia	Sí	No	No
Gestionar otros catálogos y parámetros	Sí	No	No
Gestionar usuarios	Sí	No	No
Consultar y exportar reportes	Sí	No	No
Consultar y exportar auditoría	Sí	No	No
Administrar permisos	Sí y permiso	No delegable	No delegable
Consultar y ejecutar copias	Sí y permiso	No delegable	No delegable

La política se almacena en permisos_sistema. Las excepciones de una cuenta prevalecen sobre el conjunto del rol; su representación admite heredar, permitir o denegar en la interfaz. La consulta del catálogo, el perfil propio, la contraseña propia y la salida permanecen disponibles

para cuentas activas autenticadas. Un permiso de consulta no concede automáticamente exportación, eliminación o asignación de contraseñas.

permissions.manage y backups.manage requieren siempre Administrador con su permiso, aun cuando se intentara ampliar otro rol. Debe quedar al menos un Administrador activo con permissions.manage y también se protege la existencia de un Administrador activo. Un gestor de usuarios sin permissions.manage no puede asignar otro rol ni modificar una cuenta cuyos permisos superen los propios, incluso por la ruta de contraseñas.

1. Consultar la política antes del cambio y registrar el motivo administrativo.
2. Revisar tanto el rol como las excepciones de la cuenta destino.
3. Guardar con contraseña actual y versión If-Match.
4. Verificar el resultado con la cuenta o sesión correspondiente y revisar la auditoría.
5. Ante conflicto de versión recargar y evaluar los cambios concurrentes antes de repetir.

La API relee la política en las solicitudes y vuelve a comprobar permisos antes de confirmar escrituras o entregas. La revocación no espera al vencimiento del JWT. La interfaz actualiza sus accesos y botones con la sesión, pero no constituye la barrera de autorización principal.

Autenticación y sesiones

Tabla 4 Parámetros de autenticación

Control	Valor o comportamiento
Fallos de login	Tres consecutivos por cuenta.
Bloqueo	Cinco minutos; no se evita con otra IP o navegador.
Access token	JWT HS256 de quince minutos con firma, emisor, audiencia, sub y sid.
Sesión	Máximo absoluto de siete días y diez minutos de inactividad.
Refresh	Rotación con hash persistido y control de reutilización.
Contexto del navegador	Cookie y coordinación entre pestañas; no mezclar identidades de sesiones distintas.

Control	Valor o comportamiento
Confirmación de cambios	Contraseña actual; tres fallos revocan la sesión compartida.
Actividad	Se comunica por acciones reales; leer datos o renovar credenciales no prolonga por sí mismo la sesión.

La credencial de acceso se mantiene en memoria del cliente. Las cookies de contexto y refresh son HttpOnly y se marcan Secure en producción. Las operaciones con cookies verifican origen autorizado o Referer de origen permitido conforme al contrato. No se aceptan orígenes arbitrarios ni se confía en encabezados de proxy salvo el loopback configurado.

La reutilización de un refresh conocido consumido o revocado puede revocar todas las sesiones de la cuenta. Existe una ventana de cinco segundos para concurrencia legítima con contexto correcto y sesión vigente; no habilita reutilizar credenciales invalidadas por cambio de contraseña. Las pestañas serializan renovación y cambio de contraseña para evitar restaurar una cookie antigua. No borrar hashes históricos sin una política de retención definida.

Contraseñas y recuperación

El cambio personal verifica la contraseña actual bajo bloqueo, conserva la sesión actual sin ampliar sus plazos, revoca otras sesiones y consume recuperaciones pendientes. La asignación administrativa a otra cuenta revoca sesiones del destinatario y conserva la sesión del operador. No se puede leer una contraseña existente ni convertir un hash en la clave original.

La recuperación usa un token aleatorio de 32 bytes, cuyo hash SHA256 se almacena con quince minutos de vigencia y uso único. La respuesta es uniforme para correo inexistente, cuenta inactiva, límites o SMTP degradado. El límite es de tres solicitudes por correo normalizado y por IP durante una hora. Las claves de conteo en base no contienen el correo o la IP en texto claro.

SMTP exige TLS con certificado válido y versión mínima 1.2; el puerto 465 utiliza TLS implícito y los demás transportes configurados con secure false requieren STARTTLS. El servicio verifica disponibilidad al iniciar y periódicamente. No se registran enlaces, tokens ni respuestas de protocolo con datos sensibles. La cola de envío es en memoria y limitada; no

garantiza entrega durable ante cierre abrupto. Si el mensaje no llega se solicita otro enlace después de recuperar SMTP.

Confirmaciones y concurrencia

Las modificaciones o eliminaciones protegidas usan ETag e If-Match y contraseña actual en X-Confirmation-Password, con las excepciones del contrato, como el cambio personal que usa currentPassword. El encabezado representa UTF-8 en Base64; Base64 no es cifrado y por ello el transporte institucional requiere HTTPS. Los logs lo redactan y la auditoría no lo exporta.

La comprobación se repite dentro de la transacción. No guardar cambios si el registro fue modificado por otra persona: obtener la versión nueva, comparar y decidir nuevamente. Los bloqueos se ordenan para proteger actor, sesión, parámetros y referencias. Los índices únicos y las claves foráneas son el cierre de integridad, no solo una consulta previa de existencia.

Seguridad de publicaciones y adjuntos

Título, resumen y abstract se normalizan mediante Unicode NFKD, tratamiento de diacríticos, minúsculas, puntuación y espacios. Cada campo normalizado tiene su SHA256 y unicidad individual; los registros inactivos siguen reservándolos. Un hash de archivo tampoco puede reutilizarse, incluso si se retiró de una publicación. Esto impide duplicados evidentes y carreras de registro; no demuestra originalidad académica ni detecta plagio.

Tabla 5 Controles de archivo

Etapa	Control aplicado
Recepción	Multipart con tamaño limitado y permiso efectivo.
Nombre	Normalización y sustitución de caracteres de ruta o control; no se usa como ruta física.
Contenido PDF	Firma PDF admitida y terminador EOF; no basta con MIME o extensión.
Contenido TXT	UTF-8 y validación del formato implementado cuando se habilita.
Identidad	SHA256 calculado en servidor y restricción única.
Antimalware	ClamAV sin shell, firmas vigentes, timeout y concurrencia acotados.

Etapa	Control aplicado
Persistencia	Archivo limpio en directorio privado y registro CLEAN con verificación y fecha.
Vinculación	Solo un adjunto verificado y disponible, con FK de identificador y hash.
Descarga	Sesión, permiso, tamaño, hash y auditoría antes de entregar.

PDF es el formato inicial. Actualmente solo PDF y TXT tienen validadores y pueden habilitarse mediante parámetros; no se promete compatibilidad automática con nuevas extensiones. El tamaño inicial es 10 MiB y el máximo configurable 25 MiB. La validación de firma y EOF no es una validación estructural completa del estándar PDF; el antivirus tampoco garantiza ausencia absoluta de malware desconocido.

El scanner bloquea la carga si no existe el ejecutable, faltan firmas, las firmas superan la antigüedad permitida, vence el tiempo o el resultado es incompleto. No hay actualización ni reanálisis periódico de archivos instalados automáticamente por la aplicación. TIC debe operar FreshClam, revisar fechas y conservar evidencia de su funcionamiento. En Windows existe server/scripts/update-clamav.ps1 para actualizar conforme a la guía.

Operación del almacenamiento privado

1. Ubicar ATTACHMENT_DIRECTORY fuera del cliente, del directorio público y de carpetas compartidas de la web.
2. Restringir acceso a la identidad de servicio y a los responsables de recuperación. En Linux usar directorios 0700 y archivos 0600; en Windows comprobar ACL efectivas.
3. Verificar que el volumen tenga capacidad y que los archivos no se reemplacen por enlaces simbólicos.
4. Respaldar los PDF junto con un estado compatible de la base.
5. Revisar archivos sin vínculo después de cargas canceladas, sin eliminarlos indiscriminadamente.

La clave física del archivo es un UUID y extensión admitida. La lectura comprueba tipo de archivo, ausencia de enlace simbólico, tamaño y SHA256. Si el archivo falta o no coincide, no

se entrega. Un documento externo se guarda como URL HTTP o HTTPS sin credenciales; la API no lo visita, descarga ni analiza, y no controla los permisos del sitio de destino.

Auditoría inmutable

Se auditan accesos, fallos, logout y tiempos; altas y cambios bibliográficos; archivos y descargas; usuarios, roles, catálogos, parámetros y permisos; copias y rechazos de validación o seguridad. Cada evento guarda ID, fecha UTC, usuario y rol cuando se conocen, operación, recurso e identificador, publicación cuando corresponde, IP, User-Agent, sesión, resultado, detalle y valores seguros anteriores o nuevos.

El runtime posee inserción y lectura según su función, sin UPDATE ni DELETE de auditoría, y la base refuerza la inmutabilidad con mecanismos SQL. La operación de negocio utiliza la misma transacción que su evento. Si falla la inserción se revierte; si se rechaza una operación se audita luego de revertir el cambio. No se registran bodies completos, cookies, Authorization, contraseñas, hashes de contraseñas, tokens ni rutas de almacenamiento privadas.

La IP y User-Agent no prueban por sí solos la identidad de una persona. Los reportes de auditoría aplican una proyección segura y filtros, y se restringen mediante audit.read y audit.export. La ampliación de permisos permite delegarlos expresamente; el valor inicial sigue siendo Administrador. El menú no ofrece edición ni borrado de eventos.

Copias manuales de la base de datos

Los perfiles demo y production tienen archivos privados diferentes. El motor necesita pg_dump y pg_restore compatibles con la versión del servidor, una cuenta PostgreSQL dedicada de lectura, destino local privado y autorización Drive preparada. La cuenta de lectura debe poder consultar todas las tablas necesarias, incluida auditoría y _prisma_migrations, y no es la cuenta runtime ni la encargada de restaurar.

1. Revisar que DATABASE_URL, MIGRATION_DATABASE_URL y BACKUP_DATABASE_URL apunten al mismo host, puerto y base del perfil, con cuentas técnicas distintas.

2. Abrir Copias de seguridad como Administrador autorizado y elegir Crear copia ahora, o ejecutar el comando del perfil desde la raíz.

3. Esperar el resultado; el POST de la web responde 202 por aceptación y no por finalización.

4. Identificar nombre, fecha, tamaño y resultado. Abrir auditoría para conservar SHA256 y referencia del intento.

5. Verificar el archivo con pg_restore --list y realizar el ensayo de restauración descrito en este manual.

```
npm run backup -- --profile demo
# En el servidor institucional configurado
npm run backup -- --profile production
pg_restore --list "RUTA_AL_ARCHIVO.dump"
Get-FileHash -LiteralPath "RUTA_AL_ARCHIVO.dump" -Algorithm SHA256
```

La exclusión en PostgreSQL impide solapar intentos manuales y programados. El motor audita el inicio antes de ejecutar pg_dump. Crea un archivo custom temporal, verifica su cabecera e índice y lo confirma localmente. La identidad y el hash del archivo quedan asociados a su resultado. La secuencia de nombres contiene fecha, hora e identificador único.

Estados y fallos del respaldo

Tabla 6 Resultado y respuesta operativa

Estado	Condición	Respuesta
COMPLETO	Dump local y metadata remota confirmados.	Conservar conforme a política y programar ensayo de restauración.
PARCIAL	Dump local válido; subida o verificación de Drive fallida.	Conservar local, revisar autorización/conectividad y ejecutar otro intento.
FALLIDO	No se confirmó archivo local o se detectó intento interrumpido.	Revisar logs y auditoría; comprobar disco, conexión y herramientas.
EN_CURSO	Intento activo aún sin resultado final.	Consultar de nuevo; no asumir éxito por el mensaje inicial.

Si falla la confirmación final de auditoría, el motor intenta retirar solo los archivos del intento. Reserva el ID remoto antes de subir y lo registra para compensar exclusivamente ese archivo. Si Drive está inaccesible durante la compensación, TIC debe revisar el ID señalado en la

auditoría de autorización. PostgreSQL, disco y Drive no participan en una transacción distribuida. La ausencia de error de red no reemplaza la verificación del estado final.

Programación automática en el mismo servidor

La tarea diaria ejecuta el mismo comando y genera la copia local, además del envío a Drive configurado. Puede funcionar sin web y API, pero requiere PostgreSQL disponible. En demo el lanzador puede detener el clúster al salir; para una tarea de defensa el clúster debe permanecer disponible a la hora elegida. Producción utiliza un servicio PostgreSQL administrado por TIC.

```
npm run backup:schedule -- --profile production --time 02:00 --dry-run
npm run backup:schedule -- --profile production --time 02:00
# Cambiar el horario conserva la tarea del mismo perfil
npm run backup:schedule -- --profile production --time 23:30
# Deshabilitar únicamente su programación
npm run backup:schedule -- --profile production --disable
```

Verificación en Windows

1. Ejecutar primero dry-run y revisar ruta del proyecto, perfil y hora local.
2. Registrar la tarea con la cuenta de servicio autorizada. El instalador puede pedir sus credenciales y privilegios administrativos.
3. En Programador de tareas revisar desencadenador diario, acción, directorio de trabajo y cuenta.
4. Esperar una ejecución disparada por el horario; una ejecución manual de la tarea por sí sola no acredita el disparador automático.
5. Guardar evidencia de última hora, resultado, historial del sistema y archivo creado con su fecha y hora.
6. Confirmar el intento en la aplicación y comprobar el hash del archivo.

El nombre estable incluye perfil e identificador del directorio para actualizar sin duplicar ni alterar otras tareas. Windows usa StartWhenAvailable para una ejecución perdida y permite trabajar sin sesión iniciada según la cuenta configurada. No guardar la contraseña del servicio en documentos de entrega ni en el texto de la acción.

Verificación en Linux

1. Comprobar que cron o crontab esté instalado y el servicio activo.
2. Ejecutar backup:schedule con la cuenta que operará el respaldo.
3. Revisar crontab -l y el horario de la entrada propia del perfil.
4. Esperar el horario y revisar el log .local/backups/PERFIL.log y el archivo local generado.
5. Comprobar el estado final y la copia de Drive.

Cron no recupera automáticamente un horario perdido mientras el equipo estaba apagado. La hora HH:MM es local al servidor; antes de registrar confirmar su zona horaria. La planificación institucional debe usar America/Asuncion cuando ese sea el horario operativo acordado. Una prueba de generación o un dry-run no constituye evidencia de ejecución automática real.

Configuración y copia en Google Drive

El flujo utiliza Drive API v3 con cliente OAuth de escritorio y alcance drive.file. El JSON descargado de Google y el archivo de autorización del sistema son recursos distintos y privados. No utiliza una clave de cuenta de servicio ni un cliente web en este flujo. El asistente no crea proyectos Google, no publica aplicaciones en Google ni modifica automáticamente políticas de una cuenta institucional.

1. Con la cuenta y proyecto autorizados por la institución habilitar Drive API y configurar la audiencia y consentimiento de Google.
2. Crear un cliente OAuth de aplicación de escritorio y guardar su JSON en una ubicación privada del servidor.
3. Configurar DRIVE_CLIENT_FILE, DRIVE_TOKEN_FILE, DRIVE_FOLDER_NAME y el archivo de backups del perfil.
4. Ejecutar la autorización y completar el consentimiento en el navegador con la cuenta correcta.
5. Esperar que la terminal confirme la carpeta y persista DRIVE_FOLDER_ID. Recibir el callback no demuestra por sí solo que terminó la configuración.

6. Ejecutar una primera copia y comprobar COMPLETO; abrir Drive con la cuenta autorizada y revisar el archivo dentro de la carpeta correcta.

```
npm run backup:authorize -- --profile demo
# Para la cuenta propia del entorno institucional
npm run backup:authorize -- --profile production
```

El callback temporal escucha solo en 127.0.0.1 en un puerto libre, valida state y usa PKCE; vence a los cinco minutos. Se guarda el refresh token vinculado al cliente mediante actualización atómica; el access token se renueva en memoria. El directorio del token requiere permisos de escritura de la cuenta de servicio para una posible renovación. Ningún token debe aparecer en auditoría, comandos o capturas.

La guía del proyecto distingue audiencia externa en Prueba de Google Cloud y aplicación En producción: el modo de prueba puede exigir renovar la autorización de Drive después de siete días. Elegir el perfil local production no cambia el estado de publicación de Google. Ante invalid_grant o revocación se revisa la autorización y se repite el consentimiento con el responsable; no se desactiva la validación TLS ni se publican los tokens para resolverlo.

La subida se divide en bloques de hasta 8 MiB, con reintentos limitados y consulta del rango confirmado. El motor valida por ID el nombre, carpeta, tamaño y MD5. Si el proceso se interrumpe no conserva la sesión de subida entre ejecuciones; se inicia otra copia. El alcance drive.file delimita archivos creados o autorizados para esa aplicación; un ID o enlace no otorga acceso por sí mismo.

Acreditar acceso restringido y recuperar el archivo remoto

1. Abrir la carpeta con la cuenta autorizada y revisar su administración de acceso. No habilitar acceso público para la defensa.
2. Registrar que el archivo no tiene permisos de lectura para cualquier persona con el enlace; evitar capturar direcciones privadas innecesarias.
3. Descargar el dump elegido a una carpeta privada del equipo de recuperación.
4. Calcular SHA256 del archivo descargado y compararlo con el valor auditado para ese intento.
5. Conservar la evidencia de la descarga, hash y ensayo de restauración.

La aplicación confirma la metadata después de subir, pero no contiene un botón de recuperación del dump desde Drive. La descarga para recuperación se realiza con la interfaz de Drive o una herramienta autorizada. El resultado COMPLETO no acredita por sí solo esta descarga ni la política de acceso de una carpeta modificada después por un operador.

Restauración de PostgreSQL

Restaurar es una operación de TIC. Se realiza primero en una base nueva, sin sobrescribir la base activa. El dump representa un estado tomado durante la copia y no permite recuperación a un instante intermedio entre respaldos. Las cuentas técnicas globales, los adjuntos y la configuración requieren recuperación separada. Un intento de respaldo puede aparecer EN_CURSO en su propia captura porque su resultado final se confirmó después de tomar el dump.

1. Identificar archivo, fecha, origen y SHA256. Si viene de Drive, comprobar su hash después de descargar.
2. Preparar roles en el servidor de recuperación; el dump de una sola base no crea roles globales.
3. Crear una base vacía con un propietario autorizado. No usar para restaurar la cuenta de lectura de copias.
4. Revisar pg_restore --list y ejecutar la restauración en una sola transacción, sin propietarios o ACL del servidor de origen.
5. Aplicar los grants del runtime mediante server/scripts/runtime-grants.sql con el nombre real de su rol.
6. Comprobar conteos, FK, autoría y tutoría, cuentas, permisos, clasificaciones y auditoría.
7. Recuperar los PDF correspondientes y comparar sus hashes; abrir la aplicación compatible contra el destino de prueba.
8. Registrar resultados y autorizar el cambio solo cuando la prueba sea satisfactoria. Conservar la base anterior durante la comprobación.

```
# Ejemplo que requiere adaptar host, cuenta y archivo al servidor autorizado
createdb --host=127.0.0.1 --port=5432 --username=USUARIO_ADMIN --owner=fcea_production_owner
fceadatasys_recuperada
```

```
pg_restore --host=127.0.0.1 --port=5432 --username=fcea_production_owner --
dbname=fceadatasys_recuperada --no-owner --no-acl --single-transaction --exit-on-error
"RUTA_AL_ARCHIVO.dump"
psql --host=127.0.0.1 --port=5432 --username=fcea_production_owner --
dbname=fceadatasys_recuperada -v app_role=fcea_production_app -f server/scripts/runtime-
grants.sql
```

Las palabras USUARIO_ADMIN y RUTA_AL_ARCHIVO son posiciones que TIC sustituye por los valores de su instalación; no son credenciales suministradas ni comandos que deban ejecutarse literalmente. Las contraseñas se introducen por mecanismos seguros de PostgreSQL, no en los argumentos. Al cambiar el destino del perfil actualizar de forma coherente DATABASE_URL, MIGRATION_DATABASE_URL y BACKUP_DATABASE_URL, conservando el usuario técnico de cada una.

Ensayo real de restauración de esta entrega

Se restauró directamente el dump demo recuperado de Google Drive en un clúster temporal aislado de PostgreSQL 18, sin modificar las bases demo ni institucional. El procedimiento usó --no-owner, --no-acl, --single-transaction y --exit-on-error. Después se comprobaron los datos y la presencia de autor y tutor en todas las publicaciones. El clúster temporal se detuvo y retiró al finalizar.

Tabla 7 Resultado del ensayo de recuperación

Dato	Resultado
Archivo	Software/FCEA-Datasys-demo.dump
Tamaño	93829 bytes
Resultado	APROBADO
Usuarios	3
Publicaciones	8
Autores	14
Tutores	12
Adjuntos registrados	8
Eventos de auditoría	85

Dato	Resultado
Publicaciones sin autor o tutor	0
Entradas del índice	157

SHA256 del dump entregado.
741332863e155da07f8171f78295929742929963c0665deb849e46868b2bb1ce

El registro completo está en Evidencias/restauracion.json. Este ensayo acredita la restauración del archivo descargado de Drive. Su SHA256 coincide con la copia local y con el registro auditado. Se comprobaron también los ocho archivos privados contra sus hashes y tamaños del dump. El registro recuperacion-drive.json confirma que solo existe el permiso de propietario y no hay acceso público. No se presenta como una prueba completa de la aplicación contra el destino restaurado.

Copias de adjuntos configuración y secretos

Definir una ventana de mantenimiento o un mecanismo de captura compatible para conservar adjuntos y base del mismo estado. Los archivos privados no deben copiarse a client/public ni publicarse para descargarlos más fácilmente. Conservar configuración, certificados, roles y autorización OAuth en un destino privado independiente; no incluirlos en el ZIP académico ni en Git.

La retención no se implementa como borrado automático del producto. Investigación y TIC deben aprobar cantidad de generaciones, capacidad, destino alterno y eliminación segura cuando corresponda. Las copias contienen datos personales y hashes de credenciales; su protección requiere controles del disco y de la cuenta remota. El producto no incorpora cifrado de dump por sí mismo; no se afirma que Drive o el disco sustituyan una política institucional de cifrado.

Tabla 8 Registro operativo de continuidad

Campo	Qué registrar
Última copia correcta	Fecha, hora, perfil, nombre, SHA256 y estado local/remoto.
Ejecución automática	Nombre de tarea, cuenta autorizada, horario, última ejecución y resultado.
Ensayo	Archivo de origen, base destino, versión PostgreSQL, conteos e integridad.
Recursos adicionales	Estado de adjuntos, configuración, roles y certificados recuperados.
RPO	Pérdida de datos máxima aceptada por la institución; no fijada por el software.
RTO	Tiempo máximo de recuperación acordado y después medido en ensayo; no medido integralmente en esta entrega.

Instalación segura de producción

1. Instalar Node.js de la rama admitida, PostgreSQL 18 y ClamAV con firmas vigentes.

2. Preparar servicio PostgreSQL, almacenamiento privado, dominio y certificados TLS PEM válidos.

3. Ejecutar npm run configure -- --profile production y completar el asistente con cuentas y rutas reales.

4. Separar propietario de migración, runtime de privilegios limitados y lector de backup. Comprobar acceso a roles existentes sin restablecer sus contraseñas.

5. Configurar SMTP y probar recuperación con un destinatario autorizado; no enviar secretos a cuentas ajenas.

6. Preparar Drive y una primera copia verificada; registrar la programación con cuenta de servicio propia.

7. Abrir la aplicación con start:production, verificar health/readiness y acceso desde la red autorizada.

8. Registrar el lanzador como servicio permanente mediante el gestor institucional y revisar cierre, arranque y logs.

El asistente no instala programas del sistema operativo, crea DNS, modifica firewall, emite certificados ni registra automáticamente un servicio global de aplicación. Producción exige

HTTPS y no retrocede a HTTP si falla TLS. La API escucha en loopback; el gateway es el origen público. Las credenciales administrativas y la contraseña inicial se retiran del archivo de despliegue tras una preparación exitosa.

Si la base ya existe, conservar es la opción inicial. Recrear exige copia previa verificada, confirmación exacta y ausencia de conexiones activas; no se fuerzan desconexiones ni se eliminan roles o archivos. Esta documentación no solicita recrear ninguna base existente. El operador debe comprobar perfil, host, puerto y nombre antes de aceptar una operación destructiva.

Gestión de secretos y configuración

Tabla 9 Archivos que se mantienen privados

Recurso	Tratamiento
.local/deploy/PERFIL.env	Conexiones, JWT y configuración de operación; fuera de Git y del código público.
.local/backups/PERFIL.env	Cuenta de lectura y rutas privadas del respaldo.
JSON y token de Drive	Separados entre demo y producción; acceso limitado al servicio y responsables.
Certificado y clave TLS	La clave privada no se distribuye con la entrega académica.
Contraseñas de usuarios	Solo hashes en base. La lista de claves de demo es un recurso de prueba con acceso de evaluación.
Logs y auditoría exportada	Revisión de contenido y acceso limitado; no incluir tokens o datos innecesarios.

No imprimir variables completas para diagnosticar una conexión. Los errores deben identificar la categoría y no el valor secreto. El repositorio ignora archivos locales, pero ignorar en Git no impide que un ZIP los incluya; por ello el empaquetado de entrega utiliza una lista de archivos permitidos y excluye .local, .env, tokens, certificados, dependencias y metadatos Git.

Respuesta a incidentes

Intento de acceso o cuenta comprometida

1. Registrar fecha, cuenta afectada y eventos sin copiar credenciales.
2. Revisar auditoría de acceso, cambios de permisos y sesiones con una cuenta autorizada.
3. Retirar el acceso conforme a las reglas y cambiar credenciales mediante los flujos disponibles; revocar sesiones.
4. Si hay exposición de JWT o configuración, coordinar la rotación con TIC y reiniciar los servicios afectados.
5. Verificar permisos, comunicar el resultado al responsable y conservar la evidencia.

Archivo malicioso o alterado

1. Impedir su circulación y no entregarlo a usuarios.
2. Conservar identificador, hash y resultado de análisis en el registro del incidente.
3. Revisar la publicación vinculada y la auditoría.
4. Aplicar el procedimiento excepcional de retirada y, si corresponde, eliminación física del archivo malicioso con autorización del responsable y evidencia auditada.
5. Analizar el origen, actualizar firmas y verificar otros archivos relacionados antes de reabrir el acceso.

La documentación no afirma un botón general para borrar malware después de una carga ya aceptada. La carga detectada como maliciosa se rechaza; una detección posterior necesita actuación controlada de TIC preservando la trazabilidad. No modificar ni eliminar a mano logs de auditoría para ocultar el incidente.

Fallo de auditoría o de base de datos

1. Tomar el mensaje y la hora del fallo; no repetir masivamente una escritura.
2. Comprobar estado PostgreSQL, espacio, conexiones y permisos del runtime.
3. Confirmar por consulta si una operación incierta llegó a guardarse antes de reenviar.
4. Recuperar el servicio o iniciar el procedimiento de restauración en otra base.
5. Verificar integridad y eventos antes de reanudar operaciones.

Fallo de copia o de nube

1. Revisar el estado FALLIDO o PARCIAL y conservar la copia local verificada si existe.
2. Comprobar capacidad de disco, herramientas PostgreSQL, autorización de Drive y conectividad.
3. Si hubo compensación fallida, revisar el ID remoto del intento identificado en auditoría.
4. Ejecutar una nueva copia y comprobar todos sus resultados.
5. Actualizar el registro operativo y estimar el período sin copia exitosa.

Verificaciones periódicas

Tabla 10 Controles operativos recomendados

Momento	Revisión
Cada ejecución de backup	Estado final, archivo local, copia remota, hash y errores.
Diariamente en operación	Servicios, espacio y vigencia de firmas; el horario concreto depende del responsable.
Ante altas o bajas de personal	Cuenta activa, permisos efectivos y sesiones.
Antes de un despliegue	Backup recuperable, migraciones, grants, configuración y compatibilidad.
Después de un incidente	Causa, cambios aplicados y evidencia de recuperación.
Según política institucional	Ensayo integral de restauración y revisión de retención, capacidad, TLS y secretos.

La frecuencia anterior es una pauta de operación y no una automatización del producto. No existe monitoreo institucional ni reanálisis periódico habilitado por este documento. TIC debe designar responsables y medios concretos de alerta.

Validación y límites conocidos

En el cierre se ejecutaron 245 pruebas del servidor, 115 del cliente, 22 de despliegue y 3 de programación, con resultados finales aprobados. Son 385 pruebas; las unitarias no prueban por sí mismas ACID de PostgreSQL, envío real SMTP, autorización institucional de Drive o

ejecución del Programador de tareas. El ensayo de restauración de esta entrega utiliza PostgreSQL real y verifica el dump demo en aislamiento.

La evidencia del cierre incluye la primera copia demo a Drive y su recuperación posterior con hash y permisos verificados. El ensayo temporal de Windows se disparó automáticamente a las 15:10:22, hora de Asunción, el 27 de octubre de 2026, terminó con código cero y generó un dump local de 95.209 bytes. Su configuración, última ejecución y SHA256 están en tarea-programada-configuracion.json y tarea-programada-resultado.json. Se utilizó una sesión local conectada y después se retiró únicamente la tarea de ensayo; no se afirma haber configurado la tarea diaria institucional. Producción aún requiere su cuenta institucional, certificados, ACL, SMTP, servicio permanente y política de retención. Las muestras de búsqueda locales no garantizan tiempos de la red institucional.

Fuentes y referencias

Equipo FCEA Datasys. (2026). AGENTS.md y ampliación de permisos del 26 de octubre.

Equipo FCEA Datasys. (2026). README, docs/PERMISSIONS.md, BACKUPS.md, GOOGLE-DRIVE.md e INSTALLATION-PRODUCTION.md.

Equipo FCEA Datasys. (2026). server/docs/SECURITY.md, DATABASE.md, ATTACHMENTS.md, API.md y contratos de publicaciones y reportes, contrastados con el código vigente.

Equipo FCEA Datasys. (2026). docs/DRIVE-API-VALIDATION.md y validaciones de permisos, copias e instalación.

Equipo FCEA Datasys. (2026). Evidencias/restauracion.json y logs de validación de esta entrega.